

Scallop - Borrow Incentive

Audit Report

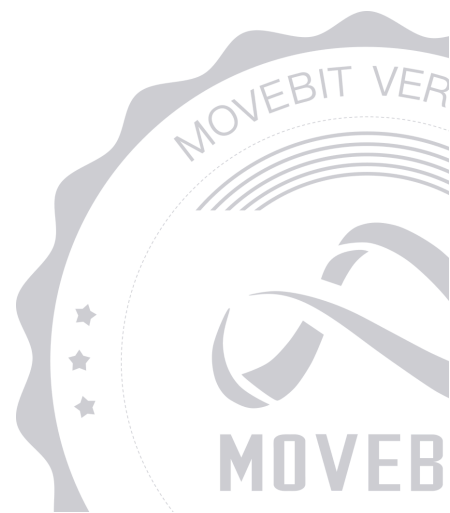


contact@bitslab.xyz



https://twitter.com/movebit_

Fri Jun 20 2025



Scallop - Borrow Incentive Audit Report

1 Executive Summary

1.1 Project Information

Description	Scallop is the pioneering Next Generation peer-to-peer Money Market for the Sui ecosystem and is also the first DeFi protocol to receive an official grant from the Sui Foundation. By emphasizing institutional-grade quality, enhanced composability, and rob
Type	DeFi
Auditors	MoveBit
Timeline	Wed Jun 04 2025 - Fri Jun 20 2025
Languages	Move
Platform	Sui
Methods	Architecture Review, Unit Testing, Manual Review
Source Code	https://github.com/scallop-io/borrow-incentive-v2
Commits	0e4f5ab6fcd87c05f2b64aca6003db3618d2707c b843639c363ee1819883f771c7172dc9b6e26b32

1.2 Files in Scope

The following are the SHA1 hashes of the original reviewed files.

ID	File	SHA-1 Hash
MMA	borrow_incentive_query/Move.mainnet.toml	ca26e8f64b987ead8074a6c2f396ebcbea0c4c1b
MOV	borrow_incentive_query/Move.toml	975523054f7145ba4075eb2223a86ca56e464be8
IAQ	borrow_incentive_query/sources/incentive_account_query.move	5a58bca694d0fe985e4ef71fff025a011b29ccc2
IPQ	borrow_incentive_query/sources/incentive_pools_query.move	38fca36ec009ec82e3304dbb1444b8ae9779679a
MMA1	borrow_incentive/Move.mainnet.toml	2d5090152929f0cf918e865d103abe97ba5bae4e
MOV1	borrow_incentive/Move.toml	02f69cfba1bfb83ad240ca8496d19911dc8649fa
IAC	borrow_incentive/sources/incentive_account.move	bd5293363f22cfc4f238f13ed18b2fa047cca406
IPO	borrow_incentive/sources/incentive_pool.move	3c75af1b2483153adb81c77293648cef203ec290
ADM	borrow_incentive/sources/admin.move	2e96ae8f1b8267a175af56690895a115a7b3d434
ICO	borrow_incentive/sources/incentive_config.move	a2a6954ba6e7860a3b5acc6a4e494fc410b3de7e

AER	borrow_incentive/sources/app_err or.move	3b5be82799aec28521dec58a3746 7f9506c8c248
IPDK	borrow_incentive/sources/incentiv e_pool_dynamic_keys.move	632fd613c8cf9c5746fd5b00e61dc4 d4c66154ca
TID	borrow_incentive/sources/typed_i d.move	89f2009c3c39a7c1443aa147b93ca 42c3da68955
UTI	borrow_incentive/sources/utils.mo ve	fe8f72d02f76f9fcb0945e8dc1951e a8e21e7290
USE	borrow_incentive/sources/user.mo ve	e1217cd468db4bbc5116766dcbf4 197f7ce7efeb

1.3 Issue Statistic

Item	Count	Fixed	Acknowledged
Total	1	1	0
Informational	0	0	0
Minor	0	0	0
Medium	1	1	0
Major	0	0	0
Critical	0	0	0

1.4 MoveBit Audit Breakdown

MoveBit aims to assess repositories for security-related issues, code quality, and compliance with specifications and best practices. Possible issues our team looked for included (but are not limited to):

- Transaction-ordering dependence
- Timestamp dependence
- Integer overflow/underflow by bit operations
- Number of rounding errors
- Denial of service / logical oversights
- Access control
- Centralization of power
- Business logic contradicting the specification
- Code clones, functionality duplication
- Gas usage
- Arbitrary token minting
- Unchecked CALL Return Values
- The flow of capability
- Witness Type

1.5 Methodology

The security team adopted the "**Testing and Automated Analysis**", "**Code Review**" and "**Formal Verification**" strategy to perform a complete security test on the code in a way that is closest to the real attack. The main entrance and scope of security testing are stated in the conventions in the "Audit Objective", which can expand to contexts beyond the scope according to the actual testing needs. The main types of this security audit include:

(1) Testing and Automated Analysis

Items to check: state consistency / failure rollback / unit testing / value overflows / parameter verification / unhandled errors / boundary checking / coding specifications.

(2) Code Review

The code scope is illustrated in section 1.2.

(3) Formal Verification(Optional)

Perform formal verification for key functions with the Move Prover.

(4) Audit Process

- Carry out relevant security tests on the testnet or the mainnet;
- If there are any questions during the audit process, communicate with the code owner in time. The code owners should actively cooperate (this might include providing the latest stable source code, relevant deployment scripts or methods, transaction signature scripts, exchange docking schemes, etc.);
- The necessary information during the audit process will be well documented for both the audit team and the code owner in a timely manner.

2 Summary

This report has been commissioned by [Scallop](#) to identify any potential issues and vulnerabilities in the source code of the [Scallop - Borrow Incentive](#) smart contract, as well as any contract dependencies that were not part of an officially recognized library. In this audit, we have utilized various techniques, including manual code review and static analysis, to identify potential vulnerabilities and security issues.

During the audit, we identified 1 issues of varying severity, listed below.

ID	Title	Severity	Status
USE-1	<code>refresh_inactive_boost</code> Unbind Without Synchronization And Unsubscribe	Medium	Fixed

3 Participant Process

Here are the relevant actors with their respective abilities within the [Scallop - Borrow Incentive](#) Smart Contract :

Admin

- `create_incentive_pools` : Create incentive pools and incentive accounts
- `add_points/take_points` : Add or extract reward points for the incentive pool
- `add_delegated_authority/remove_delegated_authority` : Add or remove the administrator addresses that have the authority to operate
- `add_rewards/ take_rewards` : Add or withdraw reward coins to the incentive pool
- `update_incentive_pool_params_v2` Update the parameters of the excitation pool
- `add_similar_coin/remove_similar_coin` : Add or remove the Similar Currency type to the incentive pool
- `enable/disable` : Enable or disable the incentive system
- `upgrade_version` Upgrade the configuration version of the incentive system
- `update_reward_fee_pool_config` Update the handling fee configuration of the reward pool
- `refresh_incentive_boost_v2` Force refresh the veSCA boost status of a certain user

User

- `update_points` : Accumulate and settle the points rows of the incentive pool and the incentive account
- `stake_with_ve_sca_v2` : Users use veSCA for staking and bind veSCA to the incentive account
- `stake` : Ordinary staking that does not involve veSCA binding
- `unstake_v2` Unbind the stake. If there is a veSCA binding, unbind it at the same time and unsubscribe

- `force_unstake_unhealthy_v2` If the health level is insufficient, it will be forcibly unbound
- `refresh_inactive_boost` After veSCA boost fails, unbind and recalculate stake
- `deactivate_boost_v2` veSCA holders voluntarily removed boost
- `redeem_rewards` Users claim rewards

4 Findings

USE-1 refresh_inactive_boost Unbind Without Synchronization And Unsubscribe

Severity: Medium

Status: Fixed

Code Location:

borrow_incentive/sources/user.move#406-457

Descriptions:

In features like unstake_v2 and stake, binding and subscribing, unbinding and unsubscribing are synchronized, but in the refresh_inactive_boost function, unbinding is not synchronized with unsubscribing

```
public entry fun refresh_inactive_boost(  
    incentive_config: &IncentiveConfig,  
    incentive_pools: &mut IncentivePools,  
    incentive_accounts: &mut IncentiveAccounts,  
    ve_sca_table: &VeScaTable,  
    obligation: &mut Obligation,  
    clock: &Clock,  
    ctx: &mut TxContext,  
) {  
    ....  
    incentive_pool::unbind_ve_sca_from_incentive_account(  
        incentive_pools,  
        ve_sca_key_id,  
        typed_id::new(obligation),  
    );  
    incentive_account::unbind_ve_sca(incentive_accounts, obligation);  
    ....  
}
```

Suggestion:

Add the unsubscription operation

Resolution:

This issue has been fixed. The client has adopted our suggestions.

Appendix 1

Issue Level

- **Informational** issues are often recommendations to improve the style of the code or to optimize code that does not affect the overall functionality.
- **Minor** issues are general suggestions relevant to best practices and readability. They don't post any direct risk. Developers are encouraged to fix them.
- **Medium** issues are non-exploitable problems and not security vulnerabilities. They should be fixed unless there is a specific reason not to.
- **Major** issues are security vulnerabilities. They put a portion of users' sensitive information at risk, and often are not directly exploitable. All major issues should be fixed.
- **Critical** issues are directly exploitable security vulnerabilities. They put users' sensitive information at risk. All critical issues should be fixed.

Issue Status

- **Fixed:** The issue has been resolved.
- **Partially Fixed:** The issue has been partially resolved.
- **Acknowledged:** The issue has been acknowledged by the code owner, and the code owner confirms it's as designed, and decides to keep it.

Appendix 2

Disclaimer

This report is based on the scope of materials and documents provided, with a limited review at the time provided. Results may not be complete and do not include all vulnerabilities. The review and this report are provided on an as-is, where-is, and as-available basis. You agree that your access and/or use, including but not limited to any associated services, products, protocols, platforms, content, and materials, will be at your own risk. A report does not imply an endorsement of any particular project or team, nor does it guarantee its security. These reports should not be relied upon in any way by any third party, including for the purpose of making any decision to buy or sell products, services, or any other assets. TO THE FULLEST EXTENT PERMITTED BY LAW, WE DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, IN CONNECTION WITH THIS REPORT, ITS CONTENT, RELATED SERVICES AND PRODUCTS, AND YOUR USE, INCLUDING BUT NOT LIMITED TO THE IMPLIED WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, NOT INFRINGEMENT.

